

PROJET DE FIN D'ETUDES

Plateforme SecureRAG Hub

Documentation complete de la chaine DevSecOps + MLSecOps + IA

Conception, implementation, experimentation et validation
d'une plateforme Cloud Native et intelligente

Depot : YassinoMed/MasterPFE — 579 commits, 14 315 fichiers
Cluster : Kubernetes (kind, 2 noeuds EC2) — 170 pods, 25+ namespaces
Stack IA : Ollama (Qwen2.5-0.5B) + Qdrant + LiteLLM Gateway + SECAI v2
Scores : DevSecOps 98/100 — MLSecOps 99/100 — Global 98,5/100
Conformite : OWASP LLM 10/10 — NIST AI RMF 96% — EU AI Act 100%
Date : 29 septembre 2026

Verification : `bash scripts/security/test-ai-stack-final.sh`

Tests : `python3 -m pytest secai/tests/ -v`

Source LaTeX : `docs/DOCUMENTATION_COMPLETE_DEVSECOPS_MLSECOPS_AI.tex`

Chapitre — Resume

Ce document constitue la documentation complete et de reference de la chaine DevSecOps + MLSecOps + IA de la plateforme SecureRAG Hub (depot YassinoMed/MasterPFE). Il decrit l'architecture globale (cluster kind, 170 pods, 25+ namespaces), le pipeline CI/CD (8 Jenkinsfiles, quality gates bloquants), la supply chain securisee (SBOM CycloneDX, signatures Cosign, provenance SLSA, admission Kyverno), le Zero-Trust (Cilium, Istio mTLS STRICT, SPIRE/SPIFFE, Vault + ESO), la securite runtime (Falco, Tetragon, Ratify), l'observabilite (Prometheus, Grafana, Loki, OpenTelemetry, Alertmanager), la sauvegarde/reprise (Velero, RTO 4h / RPO 1h, chaos engineering) et la couche MLSecOps / securite IA (SECAI v2 : 12 guardrails, 5 pipelines, 7 endpoints ; LiteLLM ; Ollama + Qwen2.5-0.5B ; Qdrant vuln-kb ; 3 CronJobs : poisoning 15 min, drift 1h, registre 6h). Resultats mesures en direct : 159 tests SECAI PASS, 20/20 final, BUILD #30 SUCCESS (202 s), 16/16 red-team neutralises, DORA ELITE, CIS 93%, FinOps 267 \$/mois.

Mots-cles : DevSecOps, MLSecOps, LLM, RAG, Kubernetes, GitOps (ArgoCD), SLSA, SBOM, Cosign/Sigstore, Kyverno, Falco, eBPF, Zero-Trust, Vault, OWASP LLM Top 10, NIST AI RMF, EU AI Act.

Chapitre 1 — Introduction generale

1.1 Contexte

SecureRAG Hub est une application RAG securisee (microservices Laravel/PHP, React, Python) orchestree par Kubernetes. Le depot MasterPFE contient code, IaC, politiques, pipelines et preuves. Double besoin : livrer vite sans livrer vulnerable (supply chain, conteneurs, runtime) et exploiter l'IA sans la subir (injection, fuite, hallucination, poisoning, exfiltration).

1.2 Problematique

Comment concevoir, formaliser et valider experimentalement un modele unifie d'integration continue de la securite : Shift-Left, preuve cryptographique SLSA 3, detection eBPF, arbitrage par IA souveraine (RAG), couverture OWASP LLM 10/10 ?

1.3 Questions de recherche

- RQ1 : automatisation SAST/SCA/secrets -> MTTD de jours a secondes (3,8 s CI ; 2,23 s local ; 100% interception) ? [H1]
- RQ2 : provenance/immutable (SBOM + Cosign + Kyverno) vers SLSA 3 a surcout < 10% ? [H2]
- RQ3 : eBPF + RAG -> score R_workload et alerte runtime en 1,82 s, moins de fatigue SOC ? [H3]

1.4 Contributions

- Chaine DevSecOps complete et mesuree (8 pipelines, 28 scripts CI, 24 release, 21 securite, 8 politiques Kyverno Enforce).
- Couche MLSecOps originale : SECAI v2 (12 guardrails, 5 pipelines, 7 endpoints, 159 tests), LiteLLM, 3 CronJobs, registre modeles.

- Protocole experimental reproductible en 9 etapes avec preuves live (20/20, BUILD #30, 16/16, DORA ELITE).
- Conformance : OWASP LLM 10/10, NIST AI RMF 96%, EU AI Act 100%.

Chapitre 2 — Architecture globale

2.1 Topologie logique

```
Git (579 commits) --> Jenkins (BUILD #30 SUCCESS)
|--> ArgoCD (29 apps, selfHeal) --> K8s kind (170 pods, 148 Running)
SECURITE: Kyverno x8, Cosign x4, Vault Raft, SPIRE, Falco/Tetragon, Harbor, Ratify
IA: Ollama, Qdrant (vuln-kb 0.996), LiteLLM (401 sans cle), SECAI (BLOCK live)
OBS: Prometheus, Grafana (26 dash), Loki, OTel, Alertmanager | FINOPS 267$/mois
```

2.2 Inventaire cluster (29/09/2026)

Namespace	Pods	Composants
-----------	------	------------

securerag-hub	12	Ollama, Qdrant, LiteLLM, SECAI, portal, auth, postgres, Falco
---------------	----	---

securerag-prod	15	Production via ArgoCD
----------------	----	-----------------------

harbor	8	Registry prive + Trivy (8/8 healthy)
--------	---	--------------------------------------

kube-system	13	coredns, kindnet, Tetragon x2 eBPF
-------------	----	------------------------------------

argocd	8	GitOps (29 apps, selfHeal prouve)
--------	---	-----------------------------------

monitoring	8	Grafana, Prometheus, exporters
------------	---	--------------------------------

mlsecops-monitoring	9	3 CronJobs : poisoning 15min, drift 1h, registre 6h
---------------------	---	---

chaos-testing	7	Chaos Mesh (kill auth-users / 5 min)
---------------	---	--------------------------------------

jenkins	1	BUILD #30 SUCCESS (6/6, 202 s)
---------	---	--------------------------------

kyverno	4	8 politiques Enforce
---------	---	----------------------

falco / velero	4 / 3	Detection runtime / Backup BSL moto S3
----------------	-------	--

spire/vault/ratify/ESO	3/2/1/3	SPIFFE / Raft unsealed / OCI 1.1 / sync Vault->K8s
------------------------	---------	--

TOTAL	170	148 Running, 25+ namespaces
-------	-----	-----------------------------

2.3 Stack IA

Composant	Port	Rôle / Preuve
-----------	------	---------------

Ollama (Cosign)	11434	Qwen2.5-0.5B, PVC 5 Gi — inference 'Bonjour !'
-----------------	-------	--

Qdrant 1.19.1	6333/34	vuln-kb — recherche score 0.996
---------------	---------	---------------------------------

LiteLLM v1.40.0	4000	Auth Bearer, budgets — 401 sans cle
-----------------	------	-------------------------------------

SECAI v2	8001	/llm/analyze, /analyze — injection BLOCK live
----------	------	---

2.4 Arbitrage technologique

Composant	Retenu	Justification
-----------	--------	---------------

IaC	Terraform	Declaratif, multi-provider, state S3 + lock DynamoDB
-----	-----------	--

CI/CD	Jenkins CASC	Agents K8s ephemerres, isolation, as-code
-------	--------------	---

GitOps	ArgoCD	Reconciliation, drift, rollback auto
--------	--------	--------------------------------------

CNI/Runtime	Cilium+Falco	eBPF natif, <1,5% CPU
-------------	--------------	-----------------------

Supply chain	Syft+Grype+Cosign	CNCF, Sigstore keyless, CycloneDX
--------------	-------------------	-----------------------------------

Secrets	Vault + ESO	Rotation dynamique, sans Git
---------	-------------	------------------------------

IA	RAG local	Souverainete SOC, grounding anti-hallucination
----	-----------	--

Chapitre 3 — Chaîne DevSecOps

3.1 Shift-Left et sequence des 24 briques

Gitleaks -> Semgrep -> Checkov -> Terraform -> Ansible -> Docker -> Trivy -> Syft -> Gype -> Cosign -> Sigstore -> ArgoCD -> Kyverno -> Istio -> SPIFFE -> Vault -> ESO -> Falco -> Tetragon -> Prometheus -> Grafana -> Loki -> OpenTelemetry -> AI Security. Chaque default est intercepté au stade le moins coûteux (pre-commit < CI < admission < runtime).

3.2 Pre-commit et hygiène Git

Fichier .pre-commit-config.yaml (55 lignes) : Gitleaks v8.30.1, TruffleHog --only-verified --fail, shellcheck, trailing-whitespace, check-yaml, detect-private-key. .gitleaks.toml : extend defaults + ~30 allowlists (rapports, fixtures, vendor, evidence). Pas de push direct main/develop ; PR exige CI verte ; commits signés GPG.

3.3 Pipelines Jenkins (8 fichiers)

Pipeline	Contenu resume
Jenkinsfile (222 l.)	Kustomize 6 envs + kyverno ; SECAI read-only ; SBOM+Gype ; Cosign ; SLSA ; Quality Gate bloquant + 8 gates ; Verify ArgoCD
Jenkinsfile.ai (351 l.)	Semgrep ai-security+secai ; pytest 159 ; detect-secrets 2 niveaux ; picklescan+garak/13 payloads ; 4 checks supply (digest, Trivy, Cosign v3, Registry)
Jenkinsfile.cd (675 l.)	Trivy+Checkov // Cosign keyless+SBOM/VEX ; verify ; SLSA ; hermetic ; promote-by-digest ; evidence STRICT ; GitOps digest ; gates PROD (ArgoCD, k6 SLO p95<200ms, Ratify, DR, DAST) ; DORA
Jenkinsfile.dr (108 l.)	k3d ephemere ; restore ; unseal Vault ; wait 600s ; k6 ; RTO 4h/RPO 1h -> DR_VALIDATION_REPORT.md
Jenkinsfile.nightly	Cron 3h : Dependency-Check + ZAP full + Garak + Backup/Restore Velero
Jenkinsfile.perf	k6 smoke/load/stress/spike/soak, VUS scale, SLO_STRICT, publishHTML
Jenkinsfile.recette	SSH 83.229.82.46 : clone, build, digest recette, sync ArgoCD, rollout 5 deploys, smoke-tests
Jenkinsfile.weekly	Dimanche 1h : ZAP baseline + API OpenAPI + gates (UNSTABLE si High)

3.4 Scripts (28 CI + 24 release + 21 securite)

CI : Dependency-Check, hadolint, webhook, renovate, platform-tools, parse-falco/tetragon, backlog, coverage 5 apps Laravel, policy-as-code (Conftest/Kyverno/OPA), audit npm/composer, remediation-loop SECAI, ZAP DAST, validations Kyverno/OPA/Tetragon/kube-score/sonar/falco, quality-gate bloquant, evidence Jenkins, tests Laravel/Python, promotion 8 gates, sonar, mlsecops-scans, ai-security-tests. Release : SBOM Syft, validation CycloneDX STRICT, Gype, VEX, Cosign cle + keyless Fulcio/OIDC, verify, provenance SLSA, attestations in-toto, promote-by-digest/digests overlay, preuves release. Securite : drill Falco/Tetragon, preflight Kyverno, poisoning Qdrant, drift, registry, garak wrapper, test final 20/20, enforce Kyverno, filtre EPSS, CIS/kube-bench, audit hosts, Vault approle/transit, conftest, scorecard, all-checks, final-audit.

3.5 Supply chain SLSA

Build multi-stage non-root Alpine UID 10001 digest @sha256:. SBOM Syft CycloneDX par service, valide STRICT, scanne Gype --fail-on high,critical. Trivy images+FS (CRITICAL bloque ; .trivyignore = 14 CVE avec expiry + ticket SEC-001..014). Signatures Cosign cle (Vault) +

keyless (Fulcio/OIDC), attestations in-toto. Provenance SLSA (commit, builder jenkins.securerag.local). SLSA L2 demontre, L3 vise.

3.6 GitOps ArgoCD (29 apps)

App-of-Apps securerag-root (prune/selfHeal), ApplicationSets platform/observability/security/ai-governance + DR multicuster, apps eso/cert-manager/ingress/pki/harbor/vault/velero/falco-talon, projets dedies. Overlays Kustomize dev/demo/recette/staging/production/preprod/test/prod/dr + bases 12 microservices + environments/prod (quota, limitrange, netpol, RBAC). SelfHeal prouve par revert kubectl direct.

3.7 Admission Kyverno (8 Enforce)

Policy | Test prouve

verify-cosign-images | unsigned -> BLOCKED

restrict-image-references | :latest interdit, @sha256: obligatoire

require-workload-controls | 3 probes + automountServiceAccountToken: false

disallow-root-containers | runAsNonRoot, drop ALL

restrict-service-exposure | LoadBalancer interdit, NodePort allowlist

restrict-volume-types | hostPath interdit

disallow-host-network | hostNetwork absent

audit-clear-text-env-values | HTTP -> annotation exigee

3.8 Zero-Trust reseau + identites

52 NetworkPolicy default-deny partout + 1 policy/service/environnement + 11 politiques applicatives fines (k8s/network-policies/01..10) + Cilium L3-L7 + matrice NETWORK_ZERO_TRUST_MATRIX.md + NetPols AI (ollama :11434, qdrant :6333/34). Istio : 11 manifests (operator, ingress, PeerAuthentication STRICT, AuthorizationPolicy DENY+ALLOW SPIFFE, DestinationRule mTLS, virtualservices, canary, telemetry, SPIRE SDS, kiali). SPIRE 1.8.2 (spiffe://cluster.local/ns/<ns>/sa/<sa>, SVID ephemeris). Vault HA Raft 3 replicas + TLS + audit + injector, auth k8s ; ESO sync Vault->K8s. Harbor prive + Trivy. Ratify OCI 1.1.

3.9 Runtime : Falco, Tetragon, Ratify, Trivy Operator

Falco eBPF modern_ebpf + regles MITRE, Falcosidekick->Talon:2803/Wazuh/Loki ; drill cat /etc/shadow -> alerte. Tetragon v1.2.0 LSM BPF + TracingPolicy, export OTel :4317. Ratify v1.0.0 serveur :6000. Trivy Operator : 411 ConfigAuditReports.

3.10 Observabilite

Prometheus (retention 30j/10Go, SLO alerts), Grafana (26 dashboards : devsecops-overview, ha-monitoring, k6-performance, slo-security), Loki+Promtail, Tempo 2.4.1, Alertmanager (critical -> #security-alerts), OTel Collector (otel-system).

3.11 Sauvegarde, DR, chaos

Velero : schedules daily 2h / weekly vault / monthly argocd, BSL minio moto S3:9110 Available, backup Completed, backups etcd/postgres/argocd/vault. Plan DISASTER_RECOVERY_PLAN.md : RTO 4h/RPO 1h, etcd snapshot, Vault raft+unseal, ArgoCD import+resync, Velero+pg_restore. Test Jenkinsfile.dr + scripts/dr. Chaos Mesh : kill auth-users / 5 min ; MTTR < 1h.

Chapitre 4 — Chaîne MLSecOps et securite IA

4.1 Les 12 guardrails SECAI

Module	OWASP	Role
injection.py	LLM01/07	GI-01..GI-06, fail-closed (28 tests)
output_filter.py	LLM02/05	GO-01..GO-06 AWS/PKM/JWT/URI/cmd
rate_limit.py	LLM10	Token bucket 5 burst / 1 req/s
factuality.py	LLM09	Claims vs contexte (10 tests)
semantic_factuality.py	LLM09	TF-IDF + cosinus (9+27 tests)
presidio_pii.py	LLM02	NER 50+ PII (10 tests)
semantic_drift.py	LLM09	MiniLM-L6-v2 384d (8 tests)
llm_judge.py	Tous	factuality/safety/relevance (16 tests, 2 LIVE)
canary_tokens.py	LLM07	Leurres anti-extraction (15 tests)
vex_statements.py	LLM03	OpenVEX not_affected -> PASS (11 tests)
transparency_log.py	LLM03	SHA-256 chaine, anti-falsification (11 tests)
schemas.py	—	Pydantic Verdict / GuardrailVerdict

4.2 Pipelines (5) + API (7 endpoints :8001)

security_analysis.py (Trivy/Semgrep/Falco/Kyverno -> findings, batch read-only), alert_correlation.py (deterministe), evaluation.py (confidence), explanation.py (toujours human_review), remediation.py (non-bloquant). API : POST /llm/analyze (IN->Gateway->OUT, injection BLOCK sans LLM), POST /analyze (3 findings BLOCK), POST /correlate, POST /explain (requires_human_review), GET /health/ready/models. Deploy digest-pine, non-root 10001, readOnlyFS. SecureBERT cisco-ai/SecureBERT2.0-base seuil 0.80, external_llm=false, degrade heuristique.

4.3 OWASP LLM 10/10

Risque	Etat	Controles
LLM01 Injection	OK	scan avant LLM (422 GI-01), Garak 0.17
LLM02 Fuite	OK	output_filter + Presidio + etcd AES + NetPols
LLM03 Supply	OK	Cosign + digest + Jenkinsfile.ai + Modelfile
LLM04 Poisoning	OK	GGUF pine + CronJob 15 min (hash d2661aaa)
LLM05 Sorties	OK	jamais eval/exec, Pydantic
LLM06 Exposition	Partiel	advisory, no tool-call, HITL
LLM07 Prompt	OK	ConfigMap + anti-leak + canary
LLM08 Acces	OK	Qdrant ingress restreint, scoping vuln-kb
LLM09 Hallu.	OK	grounding 0.80 + factuality + drift
LLM10 DoS	OK	2 Gi, 401, max_tokens 512, TokenBucket, local

4.4 Modele Qwen2.5-0.5B

0.5B, q4_k_m GGUF (pas de pickle), 491 400 032 octets, sha256 74a4da8c...7a9db, Apache-2.0, Ollama temp 0.1 ctx 1024, PVC 5 Gi, fiche models/registry/qwen2.5-0.5b-instruct.yaml, Picklescan SAFE, Garak 2075 req. Manifests : base/ollama, base/qdrant (StatefulSet v1.16.3, non-root 1000, PDB), base/ai-gateway (litellm v1.40.0, 2 replicas, NeMo filters). Note : secail/ = prod ; ai-security-service/ = prototype 4 couches ; ai-security/ = utilitaires.

4.5 Surveillance : 3 CronJobs (mlsecops/cronjobs.yaml)

CronJob	Frequence	Commande
qdrant-poisoning-check	toutes les 15 min	qdrant-poisoning-check.py --check (vuln-kb 2 pts)
model-drift-check	horaire	model-drift-monitor.py --check (5 probes, 20,37 s)
model-registry-verify	toutes les 6 h	verify-model-registry.sh (hash PVC vs registre)

4.6 Red-teaming

16/16 neutralises (7 IN + 6 OUT + 3 factuality). Wrapper garak-secai-wrapper.py ; fallback 13 payloads stdlib. CVE inventee -> UNGROUNDED ; extraction -> canary ; CVE justifiee -> VEX PASS.

Chapitre 5 — Validation experimentale

5.1 Protocole (9 etapes)

Environnement exact, config as-code, scenario MITRE, activation auto, metriques (MTTD/P95/erreurs/CPU/couverture), seuil a priori, $N \geq 3$, preuves brutes (JSON/Loki/PromQL/k6), verdict PASS/FAIL/BLOCK/ALERT. T_scan 2,23 s local / 8,4 s froid ; MTTD 3,8 s CI ; T_blocking < 0,5 s ; MTTR 45 s auto / <1 h DORA.

5.2 SECAI : 159 PASS

Suite	Nb	Verdict
guardrails	28	PASS
llm_endpoint	11	PASS (jamais au LLM)
factuality / semantic	10 / 9	PASS
presidio_pii	10	PASS
transparency_log	11	PASS (anti-falsification)
semantic_drift	8	PASS
llm_judge	16	PASS (2 LIVE)
canary / vex	15 / 11	PASS
api/correl/explain/parsers/pipe/sec/thresholds	6/2/2/9/3/3/5	PASS
TOTAL	159	159 PASS

5.3 Final 20/20 + BUILD #30

test-ai-stack-final.sh : pods ollama/qdrant/gateway Running, modele PVC, 401 sans auth, chat 'Bonjour !', RAG CVE-2024-1234 (0.996), guardrails 28, /llm/analyze 11, picklescan, 16/16 red-team, BLOCK live, factuality 10, registry sha256, poisoning baseline, drift stable, Ratify OCI 1.1, 3 Cosign. Jenkins BUILD #30 SUCCESS 202 s : 6/6 stages (Simgrep 0 violation, pytest 159, 0 crypto, 16/16, 4/4 supply).

5.4 DORA / FinOps / CIS

Metrique	Valeur	Niveau
Frequency	23/24h	ELITE
Lead time	0,6h	ELITE

Failure rate | 7,4% | ELITE

MTTR | <1h | HIGH

FinOps | 267 \$/mois | t3.2xlarge x2

CIS | 14/15 (93%) | —

Complements : k6 5 profils, PHPUnit 78,4% (>70% Sonar), npm 0/231, composer clean, Checkov 42/42, evidence/2026-09-27 (10+) et 2026-09-29. Scores : DevSecOps 98/100 (-1 mTLS cloud, -1 runner), MLSecOps 99/100, global 98,5/100.

Chapitre 6 — Conformite et gouvernance

6.1 NIST AI RMF 96% (22/23)

GOVERN (Kyverno 8, IR, Jenkins 6/6, Cosign, CronJobs), MAP (Gateway->Ollama->Qdrant->SECAI, 10 risques, GI/GO, transparency), MEASURE (juge 16/16, Garak 2075, supply 4/4, 26 dashboards, factuality 27), MANAGE (LLM01>LLM09, 3 couches deterministe->NER->ML->humain, IR-401..501). Gap MG-6 equite hors-scope.

6.2 EU AI Act 100% (8/8, risque limite)

Art. 4 literacy, 12/19 logs immuables, 13 advisory, 14 human_review, 15 tests+drift, 17 GGUF, 18 tracabilite 140+ commits. Trajectoire ISO 42001 80%, SOC2 70%, ISO 27001 70%.

6.3 SLSA / SOC2 / Control Plane

SLSA L2 demontre, L3 vise. Control plane : bus NATS, RiskScore=(Sev x Ctx)+(Blast x Exploit), Evidence Graph Merkle+Cosign->S3 WORM, OPA++ ALLOW/DENY/QUARANTINE/REVIEW (fail-open CI, fail-closed prod), AI Governor read-only + Presidio + circuit-breaker + HITL. 77 documents : rapports, MLSecOps, archi, 15+ audits, guides, roadmap, phases (25), evidence.

Chapitre 7 — Exploitation : runbooks, DR, operations

7.1 Incidents IA (IR-401..501)

Playbook | Conduite

IR-401 Poisoning | DELETE /points, re-check hash d2661aaa, ingestion operateur-only

IR-402 Substitution | scale ollama 0, compare sha256 PVC vs registry, restaure GGUF

IR-403 Degradation | kubectl top, isole runner CI (lecon IR-501)

IR-404 Jailbreak | regle GI-xx + test, relance mlsecops-scans 13/13

IR-405 Fuite | GO BLOCK, purge RAG, rotation Vault/ESO

IR-501 reel 28/09 | 6443 refused 16 min -> restart control-plane 60 s, 0 perte

SEV-1 rotation immediate, SEV-2 confinement <15 min, SEV-3 <24 h. Retour normal = test final 20/20.

7.2 Operations et DR

Quick start : kind create, install_securerag_hub_all_in_one.sh, /etc/hosts, securerag-launch-all.sh --env staging, kubectl get pods/netpol. Verif : 170 pods, 29 apps ArgoCD, quality-gate.sh, extract-jenkins-evidence.sh. Guides : RUNBOOKS, OPERATIONS_GUIDE, SRE_GUIDE, DR_GUIDE,

README-DEVSECOPS. DR : RTO 4h/RPO 1h, etcd+Vault+ArgoCD+Velero+pg_restore, ENCRYPTION_PASSWORD hors-ligne. Sources : docs/INCIDENT-RESPONSE-AI.md, DISASTER_RECOVERY_PLAN.md.

```
bash scripts/security/test-ai-stack-final.sh # 20/20
python3 -m pytest secai/tests/ -v # 159 PASS
kubectl get pods -A | wc -l # ~170
kubectl get applications -n argocd # 29 apps
```

Chapitre 8 — Conclusion et perspectives

Velocite ELITE (23 depots/24h, 0,6h, 7,4%) et assurance maximale (98,5/100, OWASP 10/10, NIST 96%, EU AI Act 100%) par automatisation, preuve cryptographique et defense deterministe-d'abord. Limites : mTLS universel + runner dedie = cloud (-2 pts) ; contentions kind juillet 2026 -> distinguer choix versionne vs preuve stable, revalider avant soutenance. Perspectives : runner GPU dedie (KServe embeddings), mTLS generalise, drift auto gouverne, VEX temps reel, Evidence WORM, ISO 42001/SOC2/27001 a 100%, Kubecost, chaos avance.

Annexes et bibliographie

Annexe A : 8 Jenkinsfiles (racine) + secai/workflows/ci. Annexe B : politiques kyverno enforce/audit + mutations + exception secai. Annexe C : 28+24+21 scripts (+dr, performance, gitops). Annexe D : commandes de verification (voir encadre 7.2). Annexe E : glossaire (SBOM, SLSA, Cosign/Sigstore, Kyverno, Ratify, eBPF, GitOps, RAG, SECAI, OWASP LLM, NIST AI RMF, DORA, RTO/RPO, VEX). Bibliographie : Burns 2016, Gartner DevSecOps 2017, NIST SSDF 800-218, SP 800-190, SLSA v1, SOC2, ISO 27001, OWASP DSOMM/K8s/LLM-2025, MITRE Containers, DORA/Accelerate, Gregg BPF, Lewis RAG 2020, CNCF Security, NIST AI RMF 1.0, EU AI Act 2024/1689. Source LaTeX complete et compilable : docs/DOCUMENTATION_COMPLETE_DEVSECOPS_MLSECOPS_AI.tex (pdflatex x2).